

Security Lab Solution Document

Executive Overview & Security Posture

Created By: Paul Leone
March 18, 2026

Contents

Executive Overview & Security Posture.....	2
Lab Mission Statement	2
Architecture Principals	2
Key Capabilities Demonstrated.....	3
Security Posture.....	3
Network & Perimeter Security.....	3
Identity & Access Management.....	5
Web & Application Security	6
DNS & Name Resolution.....	7
Remote Access, Privacy & Endpoint Security	9
Observability & Monitoring	10
Alerting & Notification Infrastructure	12
Automation & Orchestration.....	12
Security Orchestration, Automation & Response (SOAR).....	14
Behavioral Threat Intelligence (CrowdSec)	14
Security Tooling & Digital Forensics.....	15
Backup & Business Continuity.....	16

Executive Overview & Security Posture

Lab Mission Statement

This enterprise-grade security lab demonstrates production-ready capabilities across Security Operations (SecOps), Systems Engineering, and Network Defense. Designed to simulate real-world enterprise environments, the lab serves as both a technical proving ground and a continuous learning platform focused on:

- **Threat Detection & Response** — Deploying SIEM/XDR platforms, orchestrating automated incident response, and implementing behavioral threat intelligence
- **Defense-in-Depth Architecture** — Building multi-layered security controls spanning network perimeter, application layer, identity management, and endpoint protection
- **Enterprise Infrastructure Operations** — Managing hybrid virtualization platforms, container orchestration, and high-availability services at scale
- **Security Engineering & Automation** — Implementing Infrastructure as Code (IaC), SOAR workflows, and policy-driven security controls

Business Value Demonstrated: This lab mirrors the security architecture, operational workflows, and technical complexity found in mid-to-large enterprise environments, providing hands-on experience directly transferable to SOC Analyst, Security Engineer, and Infrastructure Security roles.

Architecture Principals

Every design decision in this lab is guided by three core security principles that align with industry frameworks (NIST CSF 2.0, CIS Controls v8, MITRE ATT&CK):

1. Defense in Depth

Multiple independent security layers ensure that a single compromised control does not result in full system compromise. Network segmentation, application-layer filtering, endpoint monitoring, and identity verification create overlapping defensive barriers.

Technical Implementation:

- **Network perimeter:** Multi-platform firewall enforcement (pfSense HA, OPNsense, FortiGate 30D, Palo Alto VM-Series) with IDS/IPS inline blocking
- **Application layer:** WAF (SafeLine), reverse proxy authentication (Traefik/ForwardAuth)
- **Endpoint security:** EDR agents (Wazuh), vulnerability scanning (OpenVAS/Nessus)
- **Identity controls:** MFA, RBAC, PKI
- **Network visibility:** NSM sensor (Zeek + ntopng), NetFlow from Cisco and Palo Alto infrastructure

2. Secure by Design

Security controls are embedded into architecture from the ground up, not bolted on afterward. All services default to encrypted communications (TLS), authenticated access (SSO/MFA), and least-privilege authorization (RBAC).

Technical Implementation:

- **Automated PKI:** Certificate lifecycle management via StepCA + offline OpenSSL Root CA
- **Mandatory authentication:** Authentik SSO for all web services with ForwardAuth middleware
- **Encrypted DNS:** DNSSEC validation enforced; root-recursive resolution via Unbound
- **Immutable infrastructure:** IaC version control via Terraform and Ansible

3. Zero Trust Architecture

No implicit trust is granted based on network location. Every request is authenticated, authorized, and encrypted regardless of origin. Micro-segmentation and identity-aware proxies ensure continuous verification.

Technical Implementation:

- **ForwardAuth middleware:** Validates identity at the edge before proxying requests
- **Network segmentation:** VLAN-based trust zones with default-deny inter-zone ACLs
- **Certificate-based mTLS:** Service-to-service communication enforced via internal PKI
- **Identity-driven policy:** Palo Alto User-ID maps AD group membership to firewall policy
- **Mesh VPN:** Tailscale WireGuard-encrypted peer-to-peer connectivity

Key Capabilities Demonstrated

Strategic Value

- **Reduced Attack Surface:** Multi-layer controls detect and block threats at network, application, and endpoint levels
- **Operational Resilience:** High-availability architecture ensures continuous security monitoring even during maintenance
- **Compliance Readiness:** Framework alignment with NIST CSF 2.0, CIS Controls v8, and MITRE ATT&CK demonstrates audit-ready documentation
- **Scalability:** Container orchestration and IaC enable rapid deployment of new security controls without manual configuration

Engineering Depth

- **Advanced Threat Detection:** Behavioral threat intelligence (CrowdSec), multi-engine IDS/IPS (Suricata/Snort), SIEM correlation (ELK Stack/Splunk), and NSM deep inspection (Zeek/ntopng)
- **Next-Generation Firewall:** Palo Alto VM-Series with App-ID, User-ID, WildFire, GlobalProtect, and IPSec site-to-site tunnels; FortiGate 30D physical appliance for microsegmentation
- **Automated Incident Response:** SOAR workflows integrate TheHive case management, Cortex/MISP enrichment, and automated remediation via pfSense API
- **Infrastructure as Code:** Terraform and Ansible enable version-controlled, repeatable deployments with full audit trails
- **Full-Stack Observability:** Unified metrics (Prometheus), visualization (Grafana), service monitoring (Uptime Kuma, Checkmk), and NetFlow-based traffic analysis (ntopng)
- **Forensic Readiness:** Comprehensive logging, artifact preservation, and analysis tools (Volatility, KAPE, Velociraptor) support post-incident investigation

Security Posture

Network & Perimeter Security

Network Segmentation & Zone-Based Firewall



Multiple VLANs create trust boundaries between production services, internal lab systems, and isolated research environments. Four independent firewall platforms enforce stateful and next-generation inspection with default-deny rules, permitting only explicitly authorized traffic flows between zones.

Security Impact: Lateral movement is restricted; compromised systems cannot pivot freely across network segments.

Technical Details:

- **Trust zones:** Production (VLAN 10 / 192.168.1.0/24), Lab LAN1 (VLAN 100 / 192.168.100.0/24), Lab LAN2 (VLAN 200 / 192.168.200.0/24), Isolated LAN (10.20.0.0/24), DMZ (192.168.2.0/24)
- **Inter-VLAN routing:** Controlled by firewall ACLs with logged denials; Cisco 3560X provides hardware-based L2/L3 switching across six VLANs
- **Rate limiting:** Prevents port scanning and brute-force attempts across all perimeter interfaces

Multi-Platform Firewall Architecture

The lab deploys four independent firewall platforms, each enforcing a distinct layer of the security policy. All platforms use default-deny baseline rules with explicit allow policies and comprehensive logging feeding the SIEM.

Platform	Role	Zone Coverage	Key Capability
pfSense HA Cluster	Primary perimeter firewall	Prod_LAN, Lab_LAN1/2, VPN	Active/passive HA with CARP failover; IDS/IPS (Suricata + Snort); CrowdSec bouncer
OPNsense	Secondary / isolation firewall	ISO_LAN boundary	Zone-based ACLs; CrowdSec enforcement; microsegmentation for test workloads
FortiGate 30D	Management VLAN firewall	VLAN 3 / 192.168.3.0/24	Physical appliance; SSL VPN; policy-based routing; FortiOS CLI/NSE practice platform
Palo Alto VM-Series	NGFW — app/identity-layer enforcement	DMZ, ISO_LAN1, Prod_LAN, Site2	App-ID, User-ID (AD), WildFire, GlobalProtect VPN, IPsec site-to-site, NetFlow export

High-Availability Firewall Cluster

Dual pfSense VMs operate in active/passive HA mode with CARP virtual IP failover and XMLRPC state synchronization. Firewall rules, NAT configurations, aliases, and connection state tables replicate in real-time between nodes.

Security Impact: Zero downtime during maintenance; uninterrupted threat blocking during failover events.

Technical Details:

- Sub-second failover with maintained TCP session state
- Configuration sync ensures policy consistency across nodes
- Health monitoring triggers automatic failover on node failure

Cisco Physical & Virtual Infrastructure



The lab operates a mixed Cisco environment: three virtual IOS/IOS XE routers as KVM guests in Proxmox, and one physical Catalyst 3560X-24T-S Layer 3 switch. All devices participate in OSPF Area 0 for dynamic route distribution and export NetFlow to ntopng for traffic visibility.

Security Impact: Isolated routing domain for protocol testing without impacting production; ACL and routing policy validation; L2 hardening (DHCP snooping, BPDU guard, port-security, sticky MACs) on the physical switch.

Security Configuration:

- Access control: SSH v2 only; Telnet disabled; VTY lines restricted to 192.168.1.0/24 via MGMT_ACCESS ACL
- Secret hashing: Type 9 (SCRYPT) on IOS XE; service password-encryption enabled on all devices
- OSPF authentication: MD5 on all peering interfaces; passive-interface by default on all non-P2P links
- NetFlow export: All three routers export to ntopng (192.168.1.48:2056) for flow-level visibility
- L2 hardening (3560X): DHCP snooping, BPDU guard, port-security with sticky MACs; unused ports shut down in dead VLAN

Inline Intrusion Prevention System (IPS)



Suricata and Snort operate in IPS mode on firewall interfaces, actively blocking malicious traffic based on signature databases (Emerging Threats, Snort Community Rules) and behavioral anomaly detection.



Security Impact: Known exploits, malware downloads, and C2 communication blocked in real-time before reaching endpoints.

Technical Details:

- Daily signature updates via automated feed refresh
- Custom rules for lab-specific threat patterns
- Integration with CrowdSec for coordinated blocking decisions
- Alert forwarding to Wazuh SIEM for correlation with endpoint events

Vulnerability Management Program



OpenVAS and Nessus perform authenticated and unauthenticated scans across all network segments on a weekly schedule. Scan results are categorized by severity (Critical/High/Medium/Low), mapped to CVE identifiers, and tracked in asset inventory.



Security Impact: Proactive identification of exploitable weaknesses before attackers discover them; measurable reduction in attack surface over time.

Technical Details:

- Containerized deployment with custom port mapping for scan network isolation
- Automated NVT feed synchronization ensures current vulnerability definitions
- Results exported to CSV/XML for trending analysis and integration with ticketing systems
- Metrics: Mean Time to Remediate (MTTR)

Identity & Access Management

Centralized Identity Provider (IdP)



Authentik serves as the unified SSO platform, supporting OAuth2, OpenID Connect (OIDC), and LDAP protocols. All web applications authenticate through Authentik, eliminating password sprawl and enabling centralized access control.

Security Impact: Single point of authentication enforcement reduces credential theft risk; instant access revocation across all services.

Technical Details:

- Integration with 30+ services including Proxmox, Traefik, and Portainer.
- Proxy provider for applications without native SSO support
- Session management with configurable timeout and device tracking

Multi-Factor Authentication (MFA)

TOTP-based MFA (RFC 6238) is enforced at login for all users via authenticator app (Authenticator).

Security Impact: Credential stuffing and password spray attacks are mitigated; stolen passwords alone cannot grant access.

Technical Details:

- Per-application MFA policies allow risk-based authentication
- Backup codes generated for account recovery scenarios

Role-Based Access Control (RBAC)



Granular permissions are assigned via groups and roles rather than individual user accounts. Active Directory (Windows domain) and Authentik (web services) maintain synchronized role definitions.

Security Impact: Consistent policy enforcement; simplified auditing of who-has-access-to-what.

Technical Details:

- Roles mapped to job functions: Admin, SOC Analyst, Developer, Read-Only
- Least-privilege model: users granted minimum permissions required for tasks
- Periodic access reviews ensure role assignments remain current

Enterprise PKI Infrastructure



Two-tier Certificate Authority: offline OpenSSL Root CA signs intermediate certificates; online StepCA Intermediate CA handles day-to-day certificate issuance via ACME protocol (automated Let's Encrypt-style workflow).

Isolated Windows domain Active Directory Enterprise Certificate Authority also deployed for testing purposes. Supports only a small subset of certificates for internal service communication.

Security Impact: Internal services communicate over mutually authenticated TLS; man-in-the-middle attacks are prevented.

Technical Details:

- Root CA air-gapped on removable media, powered on only for intermediate signing
- Automated certificate lifecycle: issuance, renewal (30 days before expiry), revocation
- Fullchain delivery via API to Traefik, Docker containers, and Proxmox nodes

Web & Application Security

Reverse Proxy with TLS Termination



Traefik ingress controller handles all external-facing traffic, terminating TLS at the edge and routing requests to backend services. Services without native HTTPS support are protected via encrypted proxy-to-client connections.

Security Impact: Centralized certificate management; consistent TLS configuration eliminates weak cipher misconfigurations.

Technical Details:

- Automatic certificate renewal via StepCA ACME endpoint
- HTTPS redirection for all web services
- Top-level domain routing enabled to eliminate URL port requirement.

Identity-Aware Access Control (ForwardAuth)

Traefik middleware integrates with Authentik via ForwardAuth protocol. Before proxying requests, Traefik queries Authentik to validate user identity and authorization. Headers inject user context into applications.

Security Impact: Unauthorized users cannot reach protected services; applications receive verified identity claims.

Technical Details:

- Single Sign-On at the edge: authenticate once, access multiple services
- Customizable authorization rules per service (e.g., "only SOC Analyst role")

Security Headers & IP Allowlisting

Middleware enforces HTTP Strict Transport Security (HSTS), X-Frame-Options, Content-Security-Policy, and X-Content-Type-Options headers. Source IP filtering restricts access to trusted subnets (RFC 1918 ranges).

Security Impact: Protection against clickjacking, MIME-sniffing, and protocol downgrade attacks; reduced exposure to internet-sourced attacks.

Technical Details:

- CSP policies tailored per application to allow only trusted resource origins
- IP allowlists defined in Traefik dynamic configuration files

Web Application Firewall (SafeLine WAF)



SafeLine inspects HTTP/HTTPS traffic for OWASP Top 10 vulnerabilities including SQL injection, XSS, command injection, and path traversal. Rules updated weekly from threat intelligence feeds.

Security Impact: Application vulnerabilities exploited via malicious input are blocked before reaching code.

Technical Details:

- Deployed inline behind Traefik in Docker Compose stack
- Custom rule tuning reduces false positives for lab applications
- Request logging feeds into SIEM for attack pattern analysis
- Dashboard provides real-time attack visualization and blocked request statistics

DNS & Name Resolution

Integrated DNS Threat Filtering & Ad-Blocking



Unbound provides recursive DNS resolution with ad-blocking integrated directly into the resolver. Curated blocklists are ingested nightly, sanitized, and atomically deployed as Unbound-native local-data blocks. Blocked domains return NXDOMAIN, preventing outbound connections from being established.

Security Impact: Malware C2 communication and phishing domains blocked at the DNS layer before any network connection is attempted.

Technical Details:

- Blocklists sourced from Hagezi PRO, CNAME cloaking list, DoH/DoT blockers, SmartTV and platform-specific tracking feeds
- Nightly automation: download → normalize → deduplicate → syntax validate → atomic deploy → conditional reload
- Query logging forwarded to SIEM for threat hunting and anomaly detection

Privacy-Preserving Recursive DNS

Unbound queries root DNS servers directly using iterative resolution from root hints. No upstream forwarder is configured, eliminating third-party visibility into DNS query metadata.

Security Impact: No external resolver logs, processes, or retains query data; full privacy from ISP and third-party DNS providers.

Technical Details:

- DNSSEC validation enforced: harden-dnssec-stripped: yes; val-permissive-mode: no — invalid or stripped signatures return SERVFAIL
- CNAME cloaking and DoH/DoT egress blocking prevent clients from bypassing resolver controls
- Independent caches on each resolver node reduce latency and improve resilience

Authoritative DNS (home.com)



Technitium DNS provides authoritative resolution for the home.com zone. DNS01 (192.168.1.150) serves as zone master; DNS02 (192.168.1.151) maintains a full zone replica via AXFR/IXFR. Unbound forwards all home.com queries to both hosts with automatic failover.

Security Impact: Internal namespace is fully isolated from external resolvers; zone transfer ACL restricts AXFR to DNS02 only.

Technical Details:

- SOA, NS, and glue records define dns01/dns02 as authoritative for home.com
- Zone transfer ACL: AXFR permitted from 192.168.1.151 only
- DNSSEC signing available; currently disabled

High-Availability DNS Architecture

Full redundancy is implemented at all tiers. Clients configure both Unbound nodes (192.168.1.153 / 192.168.1.154) as DNS servers; failover is automatic via the client resolver. Each node maintains an independent cache. Systemd watchdog on both Unbound nodes (WatchdogSec=30s) restarts the service automatically if it becomes unresponsive.

Security Impact: DNS filtering, recursive resolution, and internal name resolution remain operational through single-node failure at any tier.

Technical Details:

- Unbound-01 (192.168.1.153) — primary recursive resolver

- Unbound-02 (192.168.1.154) — secondary recursive resolver; independent cache; node-specific TLS keys
- Technitium DNS01/DNS02 — redundant authoritative pair; zone synchronized via AXFR/IXFR
- Health monitoring via Uptime Kuma; alerts on service degradation via Discord webhook

Remote Access, Privacy & Endpoint Security

Hardened SSH Configuration



SSH access restricted to public-key authentication only; password authentication globally disabled. Root login prohibited across all Linux systems. Fail2ban monitors authentication logs for brute-force patterns.

SSH event logging in Wazuh with active response rules to block access when multiple failed logins are detected.

Security Impact: Eliminates password-based attacks; enforces accountability via key-based identity.

Technical Details:

- ED25519 keys with 4096-bit RSA fallback for legacy systems
- Connection rate limiting (MaxStartups) prevents automated scanning
- SSH keys rotated annually; compromised keys revoked via authorized_keys updates
- Automated blocking via active response rules in Wazuh

Endpoint Detection & Response (EDR)



Wazuh agents collect security telemetry from Windows, Linux, FreeBSD, and macOS endpoints. Central manager correlates events using MITRE ATT&CK-aligned rules, generating alerts for suspicious activities.

Security Impact: Real-time visibility into endpoint behavior; detection of Living-off-the-Land (LOTL) techniques and anomalous processes.

Technical Details:

- File Integrity Monitoring (FIM) alerts on unauthorized file modifications (e.g., /etc/passwd, Windows registry keys)
- Rootkit detection scans running processes and kernel modules
- Vulnerability detection cross-references installed software with NVD database
- Active Response triggers automated remediation (e.g., block IP, kill process, create alert/ticket)

Zero Trust Mesh VPN



Tailscale establishes WireGuard-encrypted peer-to-peer tunnels between devices, eliminating reliance on traditional VPN gateways. Access control lists (ACLs) define which devices can communicate.

Security Impact: Reduced attack surface; devices authenticate via identity provider (SSO) rather than shared secrets.

Technical Details:

- MagicDNS provides human-readable hostnames (e.g., server.lab.ts.net)
- Exit nodes route traffic through trusted locations for geo-restricted access

Cloudflare Tunnels for Zero-Trust Inbound Access



Services exposed via Cloudflare Tunnels require no inbound firewall rules or public IP exposure. Outbound-only connections authenticate via service tokens and proxy requests through Cloudflare's edge.

Security Impact: Port scanning and direct IP attacks impossible; DDoS protection included.

Technical Details:

- Tunnels authenticated with short-lived JWT tokens
- Per-service access policies enforce identity verification via Cloudflare Access
- Audit logs track access attempts and policy violations

Policy-Based Routing for Privacy Zones



Select subnets and containers route outbound traffic through VPN gateways (PIA, Tailscale exit nodes) using pfSense policy routing rules. Traffic never exits cleartext to ISP.

Security Impact: ISP cannot monitor browsing activity; external observers see VPN endpoint IP only.

Technical Details:

- Custom routing tables per privacy zone
- Killswitch rules drop traffic if VPN tunnel fails
- Split tunneling for services requiring local LAN access

Observability & Monitoring

Network Security Monitoring (NSM) — Zeek + ntopng

Dedicated Ubuntu-based sensor VM (192.168.1.48) running on Proxmox, purpose-built for deep packet inspection, network flow collection, and protocol metadata extraction. Operates as a passive, observe-only node — no traffic is routed through it. Log output feeds the Elastic stack for long-term retention and Brim/Zui for local forensic analysis.

Security Impact: Full protocol metadata across all monitored segments; NetFlow-based east-west and north-south visibility; passive-only design eliminates sensor as an attack vector or pivot point; SOC-grade log output for correlation, alerting, and forensic review.

Zeek — Protocol Metadata Engine:

Zeek runs in a cluster layout across three capture interfaces. All output is JSON-formatted for direct ingestion by Elastic and Brim/Zui.

- **Protocol analyzers:** DNS, HTTP, SSL/TLS, SSH, SMB, RDP, DCE-RPC
- **Frameworks:** Notice, Intel, Weird, File hashing
- **Log path:** /opt/monitoring/zeek/ (site/, logs/, spool/)

ntopng — Flow Visibility:

ntopng ingests NetFlow v9 exports from pfSense, OPNsense, Cisco routers (R1, R2, R3), and Palo Alto firewalls. Provides flow-level traffic analysis via web UI, complementing Zeek's per-connection metadata with aggregate traffic patterns, top-talkers, and bandwidth consumption.

- **NetFlow sources:** pfSense, OPNsense, Cisco R1/R2/R3, Palo Alto (all exporting to 192.168.1.48:2056)
- **Visibility:** East-west and north-south traffic; per-host/application flow aggregation
- **SIEM integration:** Flow data available for correlation with Zeek metadata and Wazuh alerts

Unified Metrics Platform



Prometheus scrapes metrics from exporters (node_exporter, pfSense/OPNsense, traefik, pihole_exporter, proxmox_exporter). Grafana visualizes metrics in role-specific dashboards (Network, Security, Infrastructure).



Security Impact: Anomaly detection via threshold alerts; visibility into resource exhaustion attacks.

Technical Details:

- 15-second scrape intervals for real-time alerting
- 90-day metric retention for trend analysis
- AlertManager routes firing alerts to Discord channels based on severity

Service Availability Monitoring



Uptime Kuma performs health checks every 60 seconds via HTTP/HTTPS probes, TCP connections, ping tests, and DNS resolution checks. Status page provides public-facing uptime reporting.

Security Impact: Immediate detection of service outages caused by attacks or misconfigurations.

Technical Details:

- TLS certificate expiration alerts (30/7/1-day warnings)
- Response time SLA tracking with historical percentile graphs
- SMTP relay and webhook integrations for automated incident response workflows

Virtualization Platform Monitoring



Pulse dashboard provides real-time visibility into Proxmox cluster health, VM/container resource utilization, backup job status, and storage performance metrics.

Security Impact: Early detection of resource exhaustion attacks (e.g., fork bombs, disk fill).

Technical Details:

- API polling of Proxmox REST endpoints
- Backup failure alerts trigger immediate notification
- Storage threshold warnings prevent service disruption

Comprehensive IT Infrastructure Monitoring



Checkmk deploys agents to monitor OS-level metrics, application services, and network devices via SNMP. Service discovery automates addition of new monitoring targets.

Security Impact: Baseline behavior profiling enables anomaly detection; unauthorized services detected automatically.

Technical Details:

- Agentless monitoring for network appliances via SNMP v3 (encrypted)
- Custom check plugins for proprietary applications
- Distributed monitoring with remote sites polling local agents

Alerting & Notification Infrastructure

Centralized Alert Hub (Discord)

Private Discord server aggregates alerts from all monitoring platforms into dedicated channels (#grafana, #wazuh, #suricata, #crowdsec, #openvas). Persistent message history enables incident timeline reconstruction.

Security Impact: No alerts lost due to email filtering; searchable archive for post-incident analysis.

Technical Details:

- Webhook URLs per alert source enable channel-specific routing
- @mention tags for high-severity alerts ensure visibility
- Channel muting during maintenance windows reduces alert fatigue

Multi-Device Push Notifications



Discord clients on Windows 11, macOS, iOS, and Android ensure alerts reach administrators regardless of location. Push notifications deliver alerts to lock screens within seconds.

Security Impact: Critical alerts (e.g., firewall failure, intrusion detected) reach responders immediately.

Technical Details:

- Notification priority levels (silent, default, urgent)
- Do Not Disturb schedules for off-hours informational alerts
- Desktop client persistence ensures no message loss during network interruptions

Authenticated Email Relay



Gmail SMTP relay with app-specific password and TLS encryption enables email notifications for services requiring traditional delivery (TheHive case updates, MISP threat intelligence reports).

Security Impact: Formal documentation trail for compliance; integration with external ticketing systems.

Technical Details:

- SPF/DKIM records prevent email spoofing
- Rate limiting prevents abuse as spam relay
- Encrypted transport (STARTTLS mandatory)

Automation & Orchestration

Infrastructure as Code (IaC)



Terraform provisions VM infrastructure, networks, and cloud resources via declarative configuration files. Ansible playbooks enforce configuration state, deploy applications, and manage secrets across heterogeneous environments (Linux, Windows, network appliances).



Security Impact: Infrastructure rebuilt from code after ransomware; configuration drift eliminated; repeatable deployments ensure consistent security baselines.

Technical Details:



- GitHub repository with branch protection, required reviews, and signed commits
- Terraform state stored in encrypted backend with versioning for rollback capability
- Ansible Vault encrypts sensitive variables (passwords, API keys, certificates)

Low-Code Workflow Automation (n8n)



n8n orchestrates complex, multi-step workflows across services via visual workflow builder with 400+ pre-built integrations. Workflows automate data enrichment, notification routing, backup verification, and operational tasks without custom code.

Security Impact: Reduced human error in repetitive tasks; faster incident response through automated enrichment and notification workflows; audit trail of all workflow executions.

Technical Details:

- Self-hosted deployment ensures sensitive data never leaves lab environment
- Credential management with AES-256 encryption at rest
- Execution history retained for troubleshooting and compliance auditing
- Version control via JSON workflow exports to Git repository

Scheduled Task Automation

Cron jobs execute recurring security and operational tasks: certificate expiration checks, backup verification, log rotation, vulnerability scan initiation, and CIS benchmark compliance validation.

Security Impact: Manual oversight eliminated; critical tasks execute reliably during off-hours; failures detected immediately via alerting.

Technical Details:

- Success/failure notifications via Discord webhooks and email relay
- Centralized cron job inventory documented in Git repository with owner attribution
- Execution logs retained for 90 days with syslog forwarding to SIEM
- Flock file locking prevents overlapping execution of long-running jobs
- Non-privileged service accounts execute jobs following least-privilege principle

Custom Automation Scripts



Python, Bash, and PowerShell scripts handle platform-specific tasks and complex data processing. Python scripts parse vulnerability scan results, correlate SIEM alerts, generate compliance reports, and interact with REST APIs. Bash scripts manage Linux system configuration and log processing. PowerShell scripts automate Windows domain operations and Active Directory management.

Security Impact: Automated compliance reporting; reduced mean time to respond via API-driven enrichment; consistent enforcement of security configurations across platforms.

Technical Details:

- Python virtual environments (venv) isolate dependencies per script; requirements.txt versioned in Git
- Error handling and exponential backoff retry logic for API reliability
- Logging to centralized syslog with structured JSON format for SIEM ingestion
- Cross-platform compatibility tested via CI/CD pipeline (Linux, Windows, macOS)

Software Patch Management



Multi-platform patch management ensures timely deployment of security updates across Linux hosts, Docker containers, and Windows systems. Automated monitoring detects outdated software and triggers update workflows.



Security Impact: Reduced attack surface through rapid deployment of security patches; centralized visibility into patch status prevents vulnerable systems from going unnoticed; SHA-256 integrity verification prevents supply chain attacks.



Technical Details:

- PatchMon: Monitors Linux hosts for outdated packages via apt/yum/dnf; alerts on available security updates with CVE mapping
- Watchtower & WUD (What's Up Docker): Monitors Docker container images for new releases; WUD sends Discord alerts when updates available; Watchtower automates container updates on approved images
- Windows Server Update Services (WSUS): Centralized management of Microsoft product updates; approval workflows ensure controlled deployment; clients pull updates from internal WSUS server reducing internet bandwidth consumption

Security Orchestration, Automation & Response (SOAR)

Incident Case Management (TheHive)



Security incidents tracked from detection through remediation in structured cases. Tasks assigned to analysts, evidence tagged with IOCs, and investigation notes timestamped. MISP integration enables automatic IOC sharing with threat intelligence community.

Security Impact: Consistent response procedures; measurable MTTR and MTTD metrics.

Technical Details:

- Case templates standardize response workflows (phishing, malware, unauthorized access)
- Cortex integration enriches observables via VirusTotal, Shodan, and custom analyzers
- Metrics dashboard tracks case volume, severity distribution, and analyst performance



Automated Response Workflows (Shuffle)



Shuffle SOAR orchestrates multi-step response actions across tools via visual workflow builder. Workflows trigger on events from Wazuh, CrowdSec, or Suricata alerts.

Security Impact: Sub-minute response times; reduced analyst workload for repetitive tasks.

Technical Details:

- Example workflow: Wazuh alert → enrich IP via VirusTotal → create TheHive case → block IP via pfSense API → notify Discord/SMTP relay
- Execution logs enable workflow optimization and troubleshooting

Behavioral Threat Intelligence (CrowdSec)

Community-Driven Threat Detection



CrowdSec engine analyzes firewall logs, SSH authentication attempts, and web server access logs using community-curated behavioral scenarios. Detections are shared with global threat intelligence network (consensual, anonymized).

Security Impact: Protection from attacks targeting other users; zero-day threat patterns detected via behavioral analysis.

Technical Details:

- 200+ scenarios from CrowdSec Hub (brute force, port scans, CVE exploitation)
- Custom scenarios developed for lab-specific applications
- Blocklist aggregation from community signals and threat feeds

Automated Enforcement via Bouncers

pfSense firewall bouncer receives blocking decisions from CrowdSec Local API and translates them into firewall rules. Malicious IPs blocked automatically across all firewall interfaces.

Security Impact: Real-time threat blocking without manual firewall rule updates.

Technical Details:

- Authenticated API communication (JWT tokens)
- Decision duration configurable (e.g., 4-hour bans, permanent blocks for severe threats)
- Remediation actions: ban (drop all packets), captcha challenge, rate limiting

Security Tooling & Digital Forensics

Offensive Security Validation (Kali ParrotOS Linux)



Dedicated attack platform validates security controls via authorized penetration testing. Tools include Nmap (service discovery), Metasploit (exploitation), Burp Suite (web app testing), and Hydra (credential testing).



Security Impact: Proactive identification of exploitable vulnerabilities before attackers find them.

Technical Details:

- Attack logs correlated with defensive tool alerts to validate detection coverage
- Post-test reports document findings and remediation recommendations

Network Forensics & Packet Analysis

Wireshark, Brim/ZUI, and tcpdump capture and analyze network traffic for incident investigation, protocol troubleshooting, and malware C2 detection.

Security Impact: Deep visibility into encrypted handshakes, anomalous protocols, and data exfiltration attempts.

Technical Details:

- PCAPs stored on NAS for long-term retention and retrospective analysis
- Zeek logs parsed for connection metadata, file extraction, and protocol anomalies
- NetworkMiner extracts credentials, files, and OS fingerprints from captures

Digital Forensics & Incident Response (DFIR)



Comprehensive DFIR toolkit including Volatility (memory forensics), KAPE (rapid triage), Autopsy (disk analysis), Eric Zimmerman Tools (Windows artifact parsing), and Velociraptor (scalable endpoint queries).



Security Impact: Post-compromise analysis determines attack scope, identifies persistence mechanisms, and supports threat attribution.

Technical Details:

- Memory dumps captured from VMs via Proxmox snapshot + vmss2core conversion
- Velociraptor agents enable live forensic collection across endpoints
- Timeline analysis correlates events across systems for attack chain reconstruction

Backup & Business Continuity

Multi-Tier Backup Strategy



Automated backups run nightly to Synology NAS and Proxmox Backup Server in VMware Workstation. Retention policy: 0 daily, 3 weekly, 1 monthly snapshots.



Security Impact: Recovery from ransomware, hardware failure, or accidental deletion within RTO/RPO targets.

Technical Details:

- Incremental backups via Proxmox Backup Server (deduplication and compression)
- Immutable snapshots prevent ransomware tampering

Snapshot-Before-Change Policy

Proxmox snapshots captured before configuration changes, system updates, or experimental modifications. Snapshots enable instant rollback with zero data loss.

Security Impact: Change assurance; failed updates do not result in prolonged outages.

Technical Details:

- Snapshot naming convention: YYYY-MM-DD_<description> (e.g., 2025-01-08_kernel-update)
- Pre-update checklist enforces snapshot creation
- Snapshot storage monitoring prevents disk exhaustion